FROTA-SENAI

Manual técnico consolidado

Arquitetura, dados, API, desenvolvimento, segurança e governança

Versão documental 1.0

26 de outubro de 2026

Uso interno — SENAI

Documento derivado dos arquivos Markdown oficiais em docs/. Não substitui o código-fonte.

Sumário

Os títulos abaixo correspondem às seções deste PDF. A fonte editável está em docs/. Diagramas Mermaid não são desenhados aqui.

Arquitetura do sistema — FROTA-SENAI
- Objetivo
- Contexto
- Componentes (Compose)
- Frontend
- Backend
- Autenticação (fluxo)
- Persistência e arquivos
- Limites de confiança
- Decisões observáveis
- Divergências encontradas

Modelo de dados — FROTA-SENAI
- Objetivo
- Diagrama ER (simplificado)
- Entidades
- Transições de Reserva
- Exclusão
- Migrations
- Índices relevantes

Referência da API — FROTA-SENAI
- Convenções
- Públicos
- Usuários e perfil
- Veículos
- Reservas
- Vistorias
- Termos
- Auditoria e relatórios (somente admin)
- Códigos HTTP frequentes
- Alertas operacionais (contrato)

Guia de desenvolvimento — FROTA-SENAI
- Ambiente
- Backend
- Frontend
- Variáveis
- Organização
- Convenções
- Migrations
- Dependências
- Revisão de alteração (recomendado)

Testes e qualidade — FROTA-SENAI
- Como executar
- Inventário (contagem de def test_ no código)
- Verificações desta revisão documental
- Lacunas
- Regressão recomendada (manual ou futura automação)

Segurança
- Autenticação e autorização
- Segredos
- Endpoints
- CORS / CSRF / HTTPS
- Validação
- Dados pessoais
- Backup
- Checklist de produção (recomendado)
- Lacunas priorizadas

Matriz de permissões
- Autenticação
- Contas e documentos
- Frota e reservas
- Frontend
- Testes que evidenciam 403

Riscos e pendências

Inventário de ativos e dependências
- Componentes internos
- Bibliotecas backend (principais)
- Frontend
- Serviços externos
- Imagens Docker
- Riscos de desatualização

Checklist de entrega e operação
- Build e testes
- Segurança
- Backup
- Deploy Compose
- Validação funcional
- Rollback
- Aprovação

Arquitetura do sistema — FROTA-SENAI

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Público	Desenvolvedores e TI
Classificação	Uso interno

Objetivo

Descrever os componentes, limites de confiança e decisões observáveis no repositório.

Contexto

O FROTA-SENAI é uma aplicação web monolítica em dois processos de entrega: API Django e SPA React. Usuários são funcionários e administradores da instituição. Integração externa comprovada: API FIPE Parallelum (consulta). E-mail e storage S3/Supabase existem no código como opção, não no Compose mínimo.

Diagrama Mermaid: consulte o arquivo Markdown correspondente.

TLS não está no `compose.yaml` (`listen 80`). HTTPS na borda é recomendação operacional, não um fato deste repositório.

Componentes (Compose)

Diagrama Mermaid: consulte o arquivo Markdown correspondente.

Serviço	Imagem / build	Porta publicada	Persistência
db	postgres:16-alpine	nenhuma	pgdata
backend	BACKEND/Dockerfile (Python 3.12)	nenhuma (rede interna 8000)	media, staticfiles
rotina	mesma imagem; SKIP_MIGRATE=1	nenhuma	media (leitura/escrita se a rotina tocar arquivos — hoje só DB)
web	SISTEMA-FINAL/Dockerfile	HTTP_PORT (80)	monta media/static somente leitura

Healthchecks: `pg_isready` no db; HTTP `http://127.0.0.1:8000/admin/login/` no backend (Host localhost); wget na raiz do Nginx.

Frontend

- React 18, React Router 6, Axios, Vite 5.
- `AuthProvider` carrega `GET /usuarios/perfil/` com Bearer.
- `ProtectedRoute` envolve `Layout` (exceto login e definir senha).
- SPA fallback no Nginx: `try_files` → `index.html`.
- `VITE_API_URL` é build-time. No Compose vale `/api` (mesmo origin).

Backend

Apps Django: `usuarios`, `veiculos`, `reservas`, `vistorias`, `termos`, `auditoria`, `relatorios`.

Autenticação API: JWT (`rest_framework_simplejwt`). CSRF aplica-se ao Django Admin (sessão), não ao fluxo JWT da SPA.

Permissão padrão: autenticado + senha já definida (`ExigeSenhaDefinida`). Login, refresh e perfil/definir-senha no primeiro acesso são exceções.

Autenticação (fluxo)

Diagrama Mermaid: consulte o arquivo Markdown correspondente.

Persistência e arquivos

- PostgreSQL: dados transacionais.
- `MEDIA_ROOT`: CNH, termos, fotos de vistoria e de veículo.
- Nginx serve `/media/` como `Cache-Control: private`.
- Alternativa `USE_SUPABASE_STORAGE=True`: S3-compatível; não é o caminho do Compose mínimo.
- Estáticos Django: `collectstatic` → volume `staticfiles` → `/static/`.

Limites de confiança

Fronteira	Controle
Internet → Nginx	Porta HTTP; TLS não está no `compose.yaml` (recomendado no proxy ou à frente)
Nginx → Gunicorn	Rede Docker interna
API → cliente	JWT; autorização por `is_admin` e dono do recurso
API → FIPE	Saída HTTPS; sem chave; falha não tratada
Disco media	Volume Docker; permissões do container
Auditoria	HMAC com chave de ambiente; append-only

O frontend não é fronteira de autorização: esconder menu `adminOnly` não protege a API.

Decisões observáveis

Ver ADRs. Resumo:

- JWT em vez de sessão para a SPA.
- Check-in/out atômico em um POST multipart, somente mobile.
- Soft-delete de usuário e veículo.
- Auditoria encadeada.
- Rotina em processo separado (não Celery).
- E-mail opt-in.

Divergências encontradas

1. Versões antigas de `README-DOCKER.md` listavam só `db`, `backend`, `web`. O `compose.yaml` e o README-DOCKER atuais incluem `rotina`.
2. `BACKEND/.env.example` descreve Render/Supabase; o `.env.example` da raiz descreve Docker Debian. Ambos são válidos para contextos diferentes.
3. `BACKEND/README.md` apontava `docs/instalacao.md` inexistente (corrigido para esta árvore).
4. Endpoints `/reservas/<id>/iniciar/` e `/finalizar/` convivem com o fluxo atual `/vistorias/registrar/`.
5. Docstring de `validar_checkout_horario_reserva` menciona “24 h”; a função não aplica teto superior.

Modelo de dados — FROTA-SENAI

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Público	Desenvolvedores e DBA
Classificação	Uso interno
ORM	Django 5.2, PostgreSQL em produção, SQLite só nos testes

Objetivo

Documentar entidades, constraints e transições presentes nas models e migrations.

Diagrama ER (simplificado)

Diagrama Mermaid: consulte o arquivo Markdown correspondente.

Entidades

Usuario (`usuarios.Usuario`)

Autenticação por `matricula` (única). `is_admin` default False. `is_active` default True. `precisa_definir_senha` no primeiro acesso. Soft-delete: `is_active=False`.

DocumentoCNH

FK usuário. `status`: pendente | aprovado | rejeitado. `data_validade` preenchida na aprovação. Arquivo em `cnh/%Y/%m/`. Sem unique de “uma CNH aprovada”; a regra de reserva usa a vigente mais recente.

TermoResponsabilidade

Entidade FIBRA/SESI/SENAI/IEL. CPF/CNH normalizados (índice). `VALIDADE_DIAS = 365`. Unicidade CPF/CNH entre usuários é validada no serializer, não por unique no banco.

Veiculo

`placa` unique. Status: disponivel | em_uso | manutencao | inativo. Soft-delete: `inativo`. `km_atual` atualizado no check-out. `data_ultima_manutencao` informativa.

FotoVeiculo

Galeria; `ordem`. Limite de quantidade na view, não no banco.

Reserva

Status: pendente | aprovada | negada | em_andamento | concluida | cancelada.

Modalidade: horario | turno. Turnos: manha (6–12), tarde (12–18), noite (18–22).

`motivo_cancelamento`: usuario | admin | falta_checkin.

`unidade_checkin`: snapshot histórico (taguatinga, gama, sobradinho, sig).

`data_devolucao_real` no check-out.

AutorizacaoCheckinAntecipado

Unique parcial: uma pendente por reserva.

EventoOperacional

`chave` unique (idempotência da rotina e de e-mails). Tipos: checkout_atrasado, cancelamento_automatico, e-mails correspondentes.

Vistoria

Unique `(reserva, tipo)` checkin|checkout. Geo opcional.

FotoVistoria

Descrições: frente, tras, lateral_esq, lateral_dir, painel.

RegistroAuditoria

Append-only. `sequencia` unique. `hash` / `hash_anterior` HMAC-SHA256. Snapshots de nomes (sem FK viva no afetado).

Transições de Reserva

Diagrama Mermaid: consulte o arquivo Markdown correspondente.

Aprovar não altera status do veículo. Check-in: veículo `disponivel` → `em_uso`. Check-out: `em_uso` → `disponivel`.

Exclusão

Recurso	Comportamento
Usuario	`is_active=False`
Veiculo	`status=inativo`
Reserva	status `cancelada` (DELETE HTTP)
Vistoria	DELETE físico, só admin
Auditoria	proibido

Migrations

Arquivos em `BACKEND/*/migrations/`. Em Docker o entrypoint executa `migrate --noinput` no `backend` (não no `rotina`, `SKIP_MIGRATE=1`).

Procedimento seguro:

1. Backup do banco e da mídia.
2. Atualizar código.
3. `docker compose up -d --build` (migrate no boot).
4. `showmigrations` e smoke test.
5. Não editar migrations já aplicadas em produção.
6. Não usar `migrate --fake` sem procedimento documentado pela equipe.

`AUDITORIA_CHAVE_INTEGRIDADE` não é migration: é configuração. Alterá-la invalida a verificação da cadeia.

Índices relevantes

- `Usuario.matricula` unique
- `Veiculo.placa` unique
- `EventoOperacional.chave` unique
- `RegistroAuditoria.sequencia` unique; `criado_em` index
- `AutorizacaoCheckinAntecipado.status` db_index
- `cpf_normalizado` / `cnh_normalizada` index
- Unique vistoria `(reserva, tipo)`

Referência da API — FROTA-SENAI

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Prefixo	`/api/`
Autenticação	`Authorization: Bearer <access>` salvo rotas públicas
Paginação	`PageNumberPagination`, `PAGE_SIZE=20` (`count`, `next`, `previous`, `results`)
Formato	JSON; uploads em `multipart/form-data`
OpenAPI	Não há esquema gerado no repositório; este documento foi extraído das `urls.py` e views

Convenções

- Permissão padrão: autenticado + senha definida. Mensagem 403 de senha: “É necessário definir sua senha antes de continuar.”
- Admin: `IsAdmin` → “Apenas administradores podem realizar esta ação.”
- Filtro típico: admin vê todos; funcionário vê os próprios registros.
- Exemplos abaixo usam matrícula `f12345` e dados fictícios.

Públicos

POST `/api/usuarios/login/`

AllowAny. Corpo: `{ "matricula": "f12345", "password": "********" }`.

Primeiro acesso sem senha: `password` vazio e conta com `precisa_definir_senha` e senha não usável.

Resposta 200: `access`, `refresh`, `precisa_definir_senha`, `is_admin`, `matricula`, `nome`.

400: “Usuário ou senha inválidos.”

POST `/api/usuarios/refresh/`

SimpleJWT. Corpo: `{ "refresh": "..." }`. Rotação ativada; token antigo vai para blacklist.

Usuários e perfil

Método	Caminho	Quem
POST	`/usuarios/definir-senha/`	autenticado (1º acesso permitido)
GET	`/usuarios/perfil/`	próprio (1º acesso permitido)
GET	`/usuarios/pendencias/`	admin
GET POST	`/usuarios/cnh/`	lista: admin todas / user próprias; POST: própria
GET	`/usuarios/cnh/meu-status/`	próprio
GET	`/usuarios/cnh/<id>/`	dono ou admin
PATCH	`/usuarios/cnh/<id>/decisao/`	admin (`status`, `data_validade` ou `observacao_admin`)
GET POST	`/usuarios/`	admin
GET PATCH	`/usuarios/<id>/`	admin ou próprio
DELETE	`/usuarios/<id>/`	admin (inativa)

Filtros de listagem de usuários: `incluir_inativos`, `ativo`, `setor`, `cnh_situacao`, `termo_situacao`.

Veículos

Método	Caminho	Quem
GET	`/veiculos/`	autenticado (oculta inativos, salvo admin com query)
POST PATCH DELETE	`/veiculos/`, `/veiculos/<id>/`	admin (DELETE = inativo)
GET	`/veiculos/<id>/`	autenticado
POST DELETE	`/veiculos/<id>/imagem/`	admin
GET	`/veiculos/marcas/` … `/anos/<codigo_ano>/`	autenticado (FIPE)

Query GET veículos: `status`, `marca`, `tipo_combustivel`, `ano`, busca placa/modelo/marca.

Reservas

Método	Caminho	Quem
GET POST	`/reservas/`	GET: dono ou admin; POST: não admin
GET	`/reservas/disponibilidade/`	autenticado (`veiculo`, `data_inicio`, `data_fim`)
GET	`/reservas/relatorio/calendario/`	admin (`mes`, `ano`)
GET	`/reservas/alertas-operacionais/`	autenticado (conteúdo filtrado)
GET	`/reservas/autorizacoes-checkin/`	admin todas; user as que solicitou
PATCH	`/reservas/autorizacoes-checkin/<id>/`	admin
GET PATCH	`/reservas/<id>/`	dono ou admin; PATCH só pendente
DELETE	`/reservas/<id>/`	cancela pendente/aprovada; admin precisa `justificativa`
PATCH	`/reservas/<id>/aprovar/`	admin
POST	`/reservas/<id>/checkin-antecipado/`	dono (`justificativa`)
POST	`/reservas/<id>/iniciar/`	legado, dono, mobile
POST	`/reservas/<id>/finalizar/`	legado, dono, mobile

Exemplo de criação (turno):

```
POST /api/reservas/
Authorization: Bearer eyJhbGciOi...
Content-Type: application/json

{
  "veiculo": 1,
  "modalidade": "turno",
  "turno": "manha",
  "data": "2026-11-02",
  "motivo": "VISITA TECNICA",
  "destino": "TAGUATINGA",
  "passageiros": 2
}
```

Vistorias

Método	Caminho	Quem
GET POST	`/vistorias/`	GET filtrado; POST não altera status da reserva
POST	`/vistorias/registrar/`	dono, mobile, 5 fotos; altera status
GET	`/vistorias/ultima-quilometragem/?veiculo=`	autenticado
GET POST	`/vistorias/fotos/`	dono/admin
GET DELETE	`/vistorias/fotos/<id>/`	DELETE só admin
GET	`/vistorias/<id>/`	dono/admin

Método	Caminho	Quem
DELETE	/vistorias/<id>/	admin
POST	/vistorias/<id>/upload-fotos/	dono/admin

registrar (fluxo atual da UI): reserva, tipo (checkin|checkout), unidade, quilometragem, fotos (5), descricoes alinhadas a frente/tras/lateral_esq/lateral_dir/painel. Cabeçalho X-Client-Form-Factor: mobile.

Termos

Método	Caminho	Quem
GET POST	/termos/	filtrado; POST próprio
GET	/termos/meu-status/	próprio
GET	/termos/<id>/	dono/admin
PUT/PATCH	/termos/<id>/decisao/	admin

Auditoria e relatórios (somente admin)

Método	Caminho
GET	/auditoria/acoes/
GET	/auditoria/arquivos/
GET	/auditoria/integridade/
GET	/auditoria/opcoes/
GET	/relatorios/indicadores/
GET	/relatorios/opcoes/
GET	/relatorios/exportar/ (xlsx)

Filtros de relatório: de, ate (AAAA-MM-DD), veiculo, usuario, status, turno.

Códigos HTTP frequentes

Código	Uso
200	OK, inclusive registrar idempotente
201	Criação
400	Validação (janela, fotos, justificativa, datas)
401	Token ausente/inválido
403	Perfil insuficiente ou senha não definida
404	Recurso fora do queryset (outro usuário)
405	Métodos não permitidos (auditoria é só GET)
500	Possível em falha FIPE (não tratado)

Alertas operacionais (contrato)

GET /reservas/alertas-operacionais/ devolve criticos, comuns, contagens, gerado_em.

- Não admin: reservas usuario=request.user.
- Admin: todas + comuns (pendentes e check-in antecipado pendente).

Tipos críticos: checkin_proximo_cancelamento, checkout_atrasado, cancelamento_automatico.

Guia de desenvolvimento — FROTA-SENAI

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Público	Desenvolvedores
Classificação	Uso interno

Ambiente

Recomendado: Debian/Ubuntu, Python 3.12, Node 20. Backend em `BACKEND/`, frontend em `SISTEMA-FINAL/`.

Os testes não usam o PostgreSQL de desenvolvimento: `config.test_settings` força SQLite (`BACKEND/test_db.sqlite3`).

Backend

```
cd BACKEND
python3 -m venv .venv
. .venv/bin/activate
pip install -r requirements.txt
cp .env.example .env
# Ajuste DB_* se for rodar runserver contra PostgreSQL
python manage.py migrate
python manage.py createsuperuser   # matrícula, nome, senha
python manage.py runserver 0.0.0.0:8000
python manage.py check
python manage.py test --settings=config.test_settings
```

Atalhos Windows no repositório: `run.bat`, `create_superuser.bat` (não verificados nesta revisão).

Rotina local: `python manage.py rotina_operacional` ou `--loop --intervalo 60`.

Limpeza de vistorias órfãs (comando existente): `python manage.py limpar_vistorias_orfas` — use só com entendimento do efeito; não faz parte do boot Docker.

Frontend

```
cd SISTEMA-FINAL
npm ci
npm run dev      # :5173, host true (LAN)
npm run build
npm run preview
```

Sem `VITE_API_URL`: localhost → `http://localhost:8000/api`; outro hostname → `http://<host>:8000/api`. CORS em DEBUG libera LAN nas portas 3000 e 5173.

Variáveis

Ver configuração. Nunca commitar `.env`.

Organização

Pacote	Responsabilidade
`usuarios`	Auth JWT, perfil, CNH, contas
`veiculos`	Frota, imagens, FIPE
`reservas`	Reservas, alertas, rotina, e-mail stub
`vistorias`	Check-in/out, fotos, dispositivo
`termos`	Termo e validade da conta

Pacote	Responsabilidade
auditoria	Trilha HMAC
relatorios	Indicadores e xlsx
SISTEMA-FINAL/src/pages	Telas
SISTEMA-FINAL/src/components	Layout, modais, alertas
SISTEMA-FINAL/src/context	Auth, feedback

Textos de negócio de reserva/CNH/termo são normalizados para maiúsculas no backend (aplicar_maiusculas).

Convenções

- Idioma da UI e mensagens de API: português.
- Fuso: TIME_ZONE=America/Sao_Paulo, USE_TZ=True.
- Não alterar regras de janela (±30 min, 06:00–22:00) sem testes em vistorias/tests.py e reservas/tests_operacoes.py.
- Novas views: reutilizar AuthenticatedAndPasswordSet e filtrar queryset por dono se não for admin.
- Autorização sempre no backend.

Migrations

```
python manage.py makemigrations
python manage.py migrate
```

Não edite migrations já aplicadas em produção. Não execute flush/reset_db contra dados reais.

Dependências

Backend: pinado em requirements.txt. Frontend: package-lock.json (npm ci).

Atualização: altere o arquivo de lock, rode testes/build, registre risco de licença em inventário.

Revisão de alteração (recomendado)

1. Escopo mínimo; sem “limpeza” não pedida.
2. Testes do módulo + npm run build se o frontend mudou.
3. Conferir permissões (matriz).
4. Não incluir .env, mídia nem dist/.
5. Documentar endpoints novos em api.md.

Não há pipeline CI neste repositório (lacuna).

Testes e qualidade — FROTA-SENAI

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Classificação	Uso interno

Como executar

```
cd BACKEND
.venv/bin/python manage.py test --settings=config.test_settings
.venv/bin/python manage.py test reservas.tests_operacoes --settings=config.test_settings
```

Frontend: não há Jest/Vitest. Qualidade de entrega: `npm run build`.

Lint: não há ESLint/Ruff configurados no repositório.

Inventário (contagem de `def test_` no código)

Total mapeado: 189.

Módulo	Arquivo	Qtd	Foco
usuarios	`tests.py`	23	listagem, CNH, 1º acesso, inativação
veiculos	`tests.py`	20	permissões, imagens
reservas	`tests.py`	42	14 dias, CNH, turno, pernoite, fluxo
reservas	`tests_operacoes.py`	13	antecipado, auto-cancel, checkout atrasado
vistorias	`tests.py`	29	mobile, fotos, janela, unidade, km
termos	`tests.py`	9	validade, reserva
relatorios	`tests.py`	16	403, xlsx, filtros
auditoria	`tests.py`	8	permissão, arquivos
auditoria	`test_integridade.py`	15	HMAC, imutabilidade
auditoria	`test_recusas.py`	14	justificativas

Verificações desta revisão documental

Comando	Resultado	Data
`manage.py test reservas.tests_operacoes --settings=config.test_settings`	13 OK em ~14 s	26/10/2026
`npm run build` (SISTEMA-FINAL)	OK	26/10/2026
Suíte completa 189	Não executada nesta geração da documentação	—

Lacunas

- Sem testes da API FIPE (timeout/500).
- Sem testes E2E da SPA.
- Sem teste de isolamento de alerta por terceiro usuário (houve um teste temporário na investigação de alerta alheio e foi revertido; o filtro `usuario=usuario` permanece no backend).
- Sem cobertura percentual medida (`coverage` não faz parte de `requirements.txt`).

Regressão recomendada (manual ou futura automação)

1. Login funcionário e admin; primeiro acesso.
2. Upload CNH e termo; aprovação.
3. Reserva turno e horário; conflito; 14 dias.
4. Check-in mobile com 5 fotos; check-out mesma unidade.
5. Check-in antecipado.
6. Recusa com e sem justificativa.
7. Relatório Excel (admin) e 403 (funcionário).
8. Integridade da auditoria.

9. `rotina_operacional` em reserva vencida sem check-in.

Segurança

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Classificação	Uso interno
Conformidade LGPD/OWASP	Não afirmada. Há tratamento de dados pessoais no sistema; faltam DPO, RIPD e pentest neste repositório.

Autenticação e autorização

- JWT Bearer; access 8 h; refresh 7 dias com rotação e blacklist.
- Login por matrícula; primeiro acesso sem senha usável.
- Autorização: `is_admin` + dono do objeto. Frontend apenas esconde rotas.
- Conta inativa ainda autentica; reserva bloqueada.

Segredos

- `.env` no gitignore.
- `SECRET_KEY` e `AUDITORIA_CHAVE_INTEGRIDADE` distintas e estáveis.
- Senhas SMTP nunca na documentação nem no Git.
- `auditoria/services` registra detalhes sem senha/token/arquivo (há teste de limpeza).

Endpoints

- Padrão: autenticado + senha definida.
- Admin: relatórios, auditoria, pendências, decisões.
- Uploads: tipos e tamanhos nas views de veículo/CNH/termo/vistoria; Nginx `client_max_body_size 25m`.
- `/media/` com `Cache-Control: private` no Nginx — não substitui autenticação: o Nginx serve o arquivo se a URL for conhecida (lacuna: URLs enumeráveis se o nome for previsível).

CORS / CSRF / HTTPS

- CORS explícito; LAN só com `CORS_ALLOW_LAN`.
- CSRF no Admin Django.
- Compose escuta HTTP. HTTPS: recomendado no proxy; `SECURE_PROXY_SSL_HEADER` só com TLS real.
- Sem HSTS/configuração Django de cookies secure no `settings.py` analisado (lacuna em HTTP puro).

Validação

- Serializers DRF, maiúsculas em campos de texto de reserva.
- CNH numérica validada no termo.
- Check-in mobile: cabeçalhos podem ser forjados por cliente HTTP; é sinal, não atestado de hardware.

Dados pessoais

Presentes: nome, matrícula, e-mail, telefone, CPF, número de CNH, fotos do veículo e eventualmente do interior (painel). Base legal e retenção: pendente de política institucional.

Backup

Ver backup-restauracao.md. Sem job automático no Compose.

Checklist de produção (recomendado)

- [ ] `DEBUG=False`
- [ ] `SECRET_KEY` e HMAC fortes e únicos
- [ ] `ALLOWED_HOSTS` mínimo + localhost para healthcheck
- [ ] CORS/CSRF alinhados à origem pública
- [ ] TLS na frente do Nginx
- [ ] `FROTA_EMAIL_ENABLED` só com SMTP oficial
- [ ] `USE_SUPABASE_STORAGE` coerente com a topologia
- [ ] Backup ensaiado
- [ ] Superusuário criado; senhas iniciais trocadas
- [ ] Volumes sem `down -v`
- [ ] Integridade da auditoria após o go-live
- [ ] Revisão de quem possui `is_admin=True`

Lacunas priorizadas

Prioridade	Item	Evidência
Alta	HTTPS não vem no Compose	`nginx/default.conf` listen 80
Alta	`/media/` sem auth no Nginx	`alias /var/www/media`
Alta	Backup não agendado	ausência de cron no repo
Média	FIPE sem tratamento de erro	`services.py` + views
Média	Client mobile forjável	`dispositivo.py`
Média	Sem CI	ausência de workflows
Baixa	E-mail desligado	intencional

Matriz de permissões

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Perfis	Anônimo, funcionário (`is_admin=False`), administrador (`is_admin=True`)
Evidência	`permissions.py`, views, `App.jsx` `adminOnly`, testes de 403

Legenda: Sim = permitido; Não = recusado; Próprio = só registros do usuário.

Autenticação

Operação	Anônimo	Funcionário	Admin
Login / refresh	Sim	Sim	Sim
Definir senha (1º acesso)	Não (precisa token)	Sim	Sim
Usar API sem senha definida	Não	Não (exceto perfil/definir-senha)	Não

Contas e documentos

Operação	Funcionário	Admin
Ver próprio perfil	Sim	Sim
Listar usuários	Não	Sim
Criar usuário	Não	Sim
Editar próprio nome/contato	Sim	Sim
Alterar `is_active` de terceiros	Não	Sim
Inativar usuário	Não	Sim (não a si)
Upload CNH/termo	Sim (próprio)	Sim (próprio; não aprova o próprio)
Decidir CNH/termo	Não	Sim
Pendências agregadas	Não	Sim

Frota e reservas

Operação	Funcionário	Admin
Listar veículos (não inativos)	Sim	Sim + inativos
Cadastrar/editar/inativar veículo	Não	Sim
Fotos do veículo	Não	Sim
Consultar FIPE	Sim	Sim
Criar reserva	Sim	Não
Ver reservas	Próprias	Todas
Aprovar/negar reserva	Não	Sim
Cancelar pendente/aprovada	Própria	Qualquer (com justificativa)
Check-in/out registrar	Própria, mobile	API: sim (admin não é bloqueado pelo serializer). UI: o botão exige `reserva.usuario === usuário logado`, então o admin não registra vistoria de terceiros pela interface
Check-in antecipado solicitar	Própria	Não
Decidir antecipado	Não	Sim
Alertas operacionais	Próprios críticos	Frota + avisos
Calendário / indicadores / Excel	Não	Sim
Auditoria	Não	Sim (somente GET)

Frontend

Rotas `adminOnly` redirecionam funcionário para `/`. Isso não é autorização.

Testes que evidenciam 403

`usuarios/tests.py`, `veiculos/tests.py`, `reservas/tests.py`, `relatorios/tests.py` (`PermissoesRelatorioTests`), `auditoria/tests.py`, `termos/tests.py`, recusas em `test_recusas.py`.

Riscos e pendências

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Classificação	Uso interno

Probabilidade e impacto são estimativas de engenharia, não análise quantitativa.

ID	Descrição	Impacto	Prob.	Evidência	Prioridade	Mitigação	Status
R01	Tráfego HTTP sem TLS no Compose	Credenciais em claro	Alta em LAN aberta	`listen 80`	Alta	Proxy TLS	Confirmado
R02	Arquivos em `/media/` sem autenticação no Nginx	Vazamento de CNH/fotos se URL vazar	Média	`nginx/default.conf`	Alta	URLs assinadas ou auth no proxy	Confirmado
R03	Sem backup automático	Perda de dados	Média	Compose sem cron	Alta	Job + ensaio de restore	Confirmado
R04	FIPE 500	Cadastro de veículo interrompido	Média	`veiculos/services.py`	Média	try/except e mensagem	Confirmado
R05	`DEBUG=True` default no settings se env omitido	Vazamento de traceback	Baixa no Compose (False)	`settings.py`	Média	Nunca omitir DEBUG em prod	Confirmado
R06	Cabeçalho mobile forjável	Check-in via script	Baixa/média	`dispositivo.py`	Média	Aceitar como política ou 2FA operacional	Confirmado
R07	Unicidade CPF/CNH só no serializer	Duplicidade concorrente	Baixa	models vs serializers termos	Baixa	unique constraint	Confirmado
R08	E-mail desligado	Alertas só na UI	—	`FROTA_EMAIL_ENABLED`	Baixa	Ativar com TI	Confirmado (intencional)
R09	Sem CI	Regressão não detectada no push	Média	ausência de workflows	Média	pipeline test+build	Confirmado
R10	Relato de alerta visível a usuário que não é o dono	Falso alarme	—	investigação 26/10/2026	—	Filtro original `usuario=usuario` restaurado	Hipótese encerrada
R11	LGPD / retenção de documentos	Jurídico	—	dados pessoais no banco e media	Alta institucional	Política e RIPD	Pendente de validação (não afirmada)
R12	Restore de dump não ensaiado	RTO desconhecido	—	docs de backup	Alta operacional	Drill em ambiente isolado	Pendente de validação (não ensaiado)
R13	Dois `.env.example` (raiz vs BACKEND)	Operador usar o arquivo errado	Média	arquivos no repo	Baixa	Seguir o da raiz no Compose	Confirmado
R14	Check-out sem teto temporal	Devolução possível muito após o fim da reserva	Média	`validar_checkout_horario_reserva` só bloqueia cedo demais; `MSG_CHECKOUT_DEPOIS` não é chamada	Média	Decidir se o teto deve ser implementado	Confirmado no código; não é pentest

Inventário de ativos e dependências

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026
Fontes	`requirements.txt`, `package-lock.json` (versões de package.json), imagens Docker

Licenças: conferidas apenas pelos nomes dos pacotes (MIT/BSD/Apache típicos). Não houve varredura `pip-licenses` nesta revisão.

Componentes internos

Ativo	Local
API Django	`BACKEND/`
SPA	`SISTEMA-FINAL/`
Nginx config	`nginx/default.conf`
Compose	`compose.yaml`
Docs	`docs/`

Bibliotecas backend (principais)

Pacote	Versão pinada
Django	5.2.17
djangorestframework	3.18.0
djangorestframework_simplejwt	5.5.1
django-cors-headers	4.9.0
django-filter	26.1
django-storages[s3]	1.14.6
gunicorn	26.0.0
psycopg2-binary	2.9.11
pillow	12.3.0
python-decouple	3.8
requests	2.34.2
PyJWT	2.13.0
boto3	>=1.35,<2
reportlab	4.4.3
openpyxl	3.1.5

Python da imagem: 3.12-slim-bookworm.

Frontend

Pacote	Faixa em package.json
react / react-dom	^18.3.1
react-router-dom	^6.26.2
axios	^1.7.7
vite	^5.4.8
@vitejs/plugin-react	^4.3.1

Node da imagem de build: 20-alpine. Nginx runtime: 1.27-alpine.

Serviços externos

Serviço	Uso	Crítico?
PyPI / npm	só build	Sim no deploy
parallelum.com.br FIPE	consulta marcas/modelos	Não (cadastro manual)
fonts.googleapis.com	tipografia SPA	Não
SMTP	e-mail operacional	Não (desligado)
Supabase	opcional DB/storage	Não no Compose mínimo

Imagens Docker

postgres:16-alpine; python:3.12-slim-bookworm; node:20-alpine; nginx:1.27-alpine.

Riscos de desatualização

Dependências pinadas reduzem surpresa, mas exigem atualização periódica (Django LTS, Pillow, urllib3). Sem Dependabot/CI neste repo.

Checklist de entrega e operação

Campo	Valor
Versão	1.0
Data	26 de outubro de 2026

Use em cada promoção de versão. Itens “não executados” devem permanecer abertos.

Build e testes

- [ ] `python manage.py test --settings=config.test_settings`
- [ ] `npm run build` em `SISTEMA-FINAL`
- [ ] Sem segredos no diff

Segurança

- [ ] `DEBUG=False` no ambiente alvo
- [ ] `.env` não versionado; chaves novas se for instalação nova
- [ ] `is_admin` revisado
- [ ] TLS se o ambiente for público
- [ ] checklist de segurança

Backup

- [ ] Dump PostgreSQL recente
- [ ] Tarball `media`
- [ ] Cópia controlada do `.env` (cofre)

Deploy Compose

- [ ] Código atualizado sem sobrescrever `.env`
- [ ] `docker compose up -d --build`
- [ ] `docker compose ps` healthy (`db`, `backend`, `rotina`, `web`)

- [ ] `showmigrations` coerente

Validação funcional

- [ ] Login admin e funcionário
- [ ] SPA em `/` e API em `/api/`
- [ ] Admin Django se utilizado
- [ ] Upload e leitura `/media/`
- [ ] Uma reserva de homologação (não produção real)

Rollback

- [ ] Imagem/código anterior disponível
- [ ] Dump pré-deploy guardado
- [ ] Procedimento backup-restauracao.md conhecido

Aprovação

Papel	Nome	Data	Assinatura
Desenvolvimento			
Operação / TI			
Gestor da frota			